

认证机制漏洞报告（Lab3：2FA 失效逻辑）

1. 漏洞名称

双因素认证逻辑失效（2FA Logic Flaw） — 验证码暴力破解

2. 漏洞等级

高危（High）

3. 漏洞描述

该网站使用了 2FA 双因素认证，但实现存在严重逻辑缺陷。在提交双重验证码时，服务器端没有将当前验证码与当前登录会话进行强绑定，而是通过请求体中的 verify 参数直接指定了正在验证的用户。攻击者可以通过修改 verify 参数为目标用户 carlos，并利用 Burp Intruder 对 4 位数字的验证码进行暴力破解，最终绕过 2FA 防护，以 carlos 的身份登录系统。

4. 漏洞位置

攻击端点：POST /login2

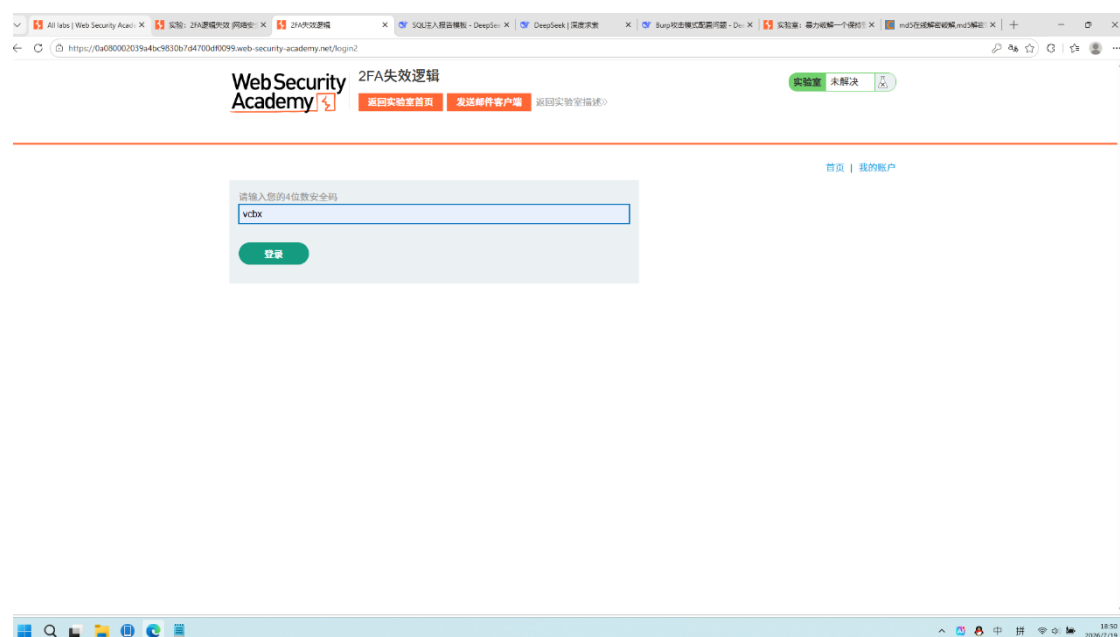
关键参数：verify（控制目标用户）、mfa-code（验证码字段）

5. 漏洞复现过程

第一步：登录与 2FA 验证入口

首先以攻击者账号 wiener:peter 登录。在触发 2FA 验证时，拦截并分析生成的 HTTP 请求。

图 1：2FA 验证码输入界面



说明：2FA 页面要求输入 4 位安全码。

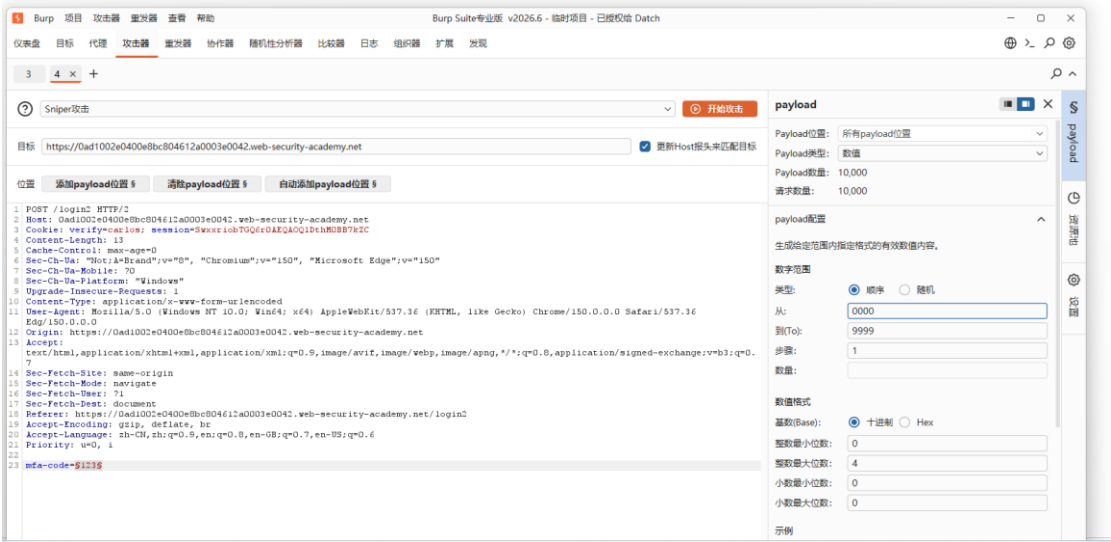
第二步：发现逻辑漏洞关键点

在 Burp 的 HTTP 历史中，发现了用于生成 2FA 验证码的请求。拦截该请求，并修改 verify 参数为 carlos，发送到 Burp Repeater。这确保了服务器为受害者 carlos 生成了临时的 2FA 代码，并允许我们绕过自己的验证码对其进行测试。

第三步：配置 Burp Intruder 进行暴力破解

捕获提交验证码的 POST /login2 请求。将 verify 参数的值修改为 carlos，并将 mfa-code 的值设置为 Payload 位置。

图 2：Burp Intruder 配置 4 位数验证码爆破

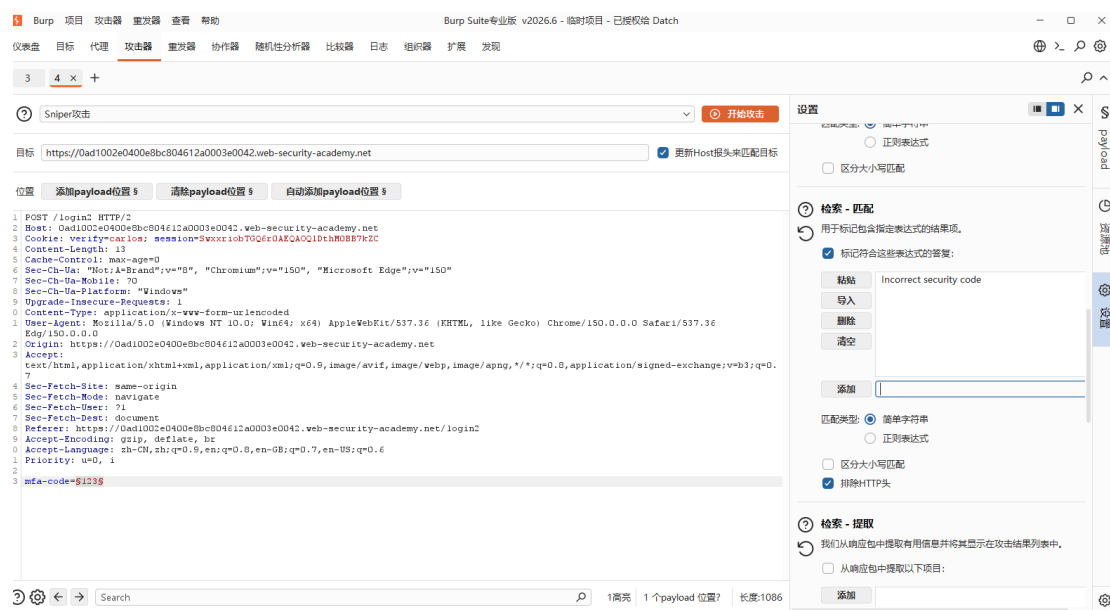


说明：由于验证码仅为 4 位数字，共有 10000 种可能，使用 Burp Intruder 进行暴力破解。

第四步：设置匹配条件，精准定位正确验证码

为了在 10000 个请求中迅速找到正确的验证码，使用 Burp 的 Grep - Match 功能进行过滤。

图 3：配置 Grep - Match 过滤错误提示

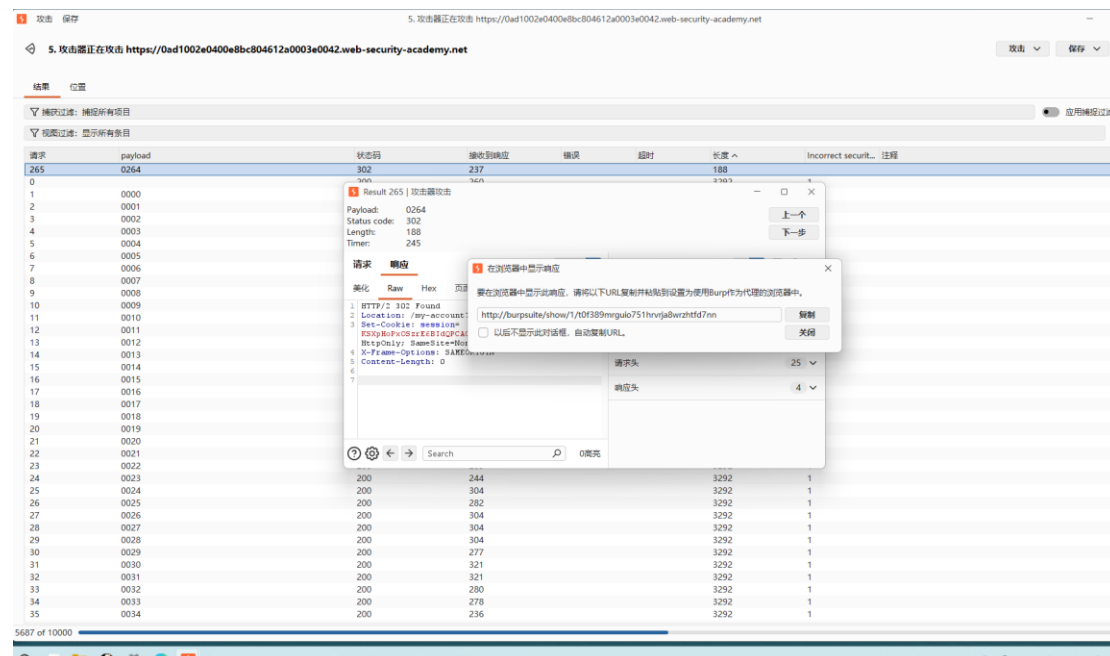


说明：当验证码错误时，响应会包含 Incorrect security code。配置此匹配项后，没有匹配到此字符串的请求即为爆破成功的请求。

第五步：成功爆破并获取登录凭证

启动攻击。在结果列表中，根据 Incorrect security code 列的标记，找到返回 302 状态码且长度明显不同的请求。

图 4：Burp 爆破成功，获取 302 跳转



说明：验证码 0264 成功绕过验证，服务器返回 302 跳转，并下发 carlos 的 Session Cookie。

第六步：成功接管目标账户

复制并利用爆破成功的 302 响应中的 Cookie 或直接在 Burp 的浏览器中渲染该响应，访问 /my-account 页面。

图 5：成功登录 Carlos 账户并完成实验



说明：成功绕过 2FA 防护，接管了受害者的账户。

6. 漏洞原理

双因素认证（2FA）的逻辑缺陷：

1. **参数可控的验证对象**：该服务器在 2FA 验证阶段，使用 verify 参数明确指定了需要验证的用户是谁。
2. **缺乏会话绑定**：服务器没有将当前用户产生的验证码与当前登录的会话（Session）进行强绑定。因此，攻击者只需将 verify 从 wiener 改为 carlos，便能把自己登录界面的验证码通道切换为 carlos。
3. **缺乏速率限制（Rate Limiting）**：系统对 4 位数的验证码提交没有次数限制，使得 10000 次尝试在几秒内即可完成。

7. 漏洞影响

- **彻底破坏 2FA 保护**：即使启用了双因素认证，攻击者也能通过暴力破解接管目标账户。
- **账户批量接管**：结合用户名枚举，攻击者可批量重置并破解任意用户的 2FA 验证码。

8. 修复建议

- ① **强会话绑定**：服务器端在处理 2FA 验证请求时，**严禁通过客户端提交的 verify 参**

数来决定验证对象。必须从当前登录的 Session 中提取已验证的用户标识，并检查生成的验证码与该用户是否匹配。

② **实施严格的速率限制：**对于同一个 IP 或同一个 verify 目标，在短时间（如 1 分钟）内允许输入失败次数不得超过 3 次，超过后锁定 15 分钟或强制重新登录。

③ **验证码有效期设置：**生成的 2FA 验证码必须设置极短的有效期（如 2 分钟），超时即作废，减少爆破窗口。

9. 工具

- **Burp Suite**（Repeater 参数篡改、Intruder 自动化爆破、Grep - Match 检索）
- **PortSwigger Web Security Academy**（靶场平台）